

ZK-CID

Zero-Knowledge Compliance Identity
& Decentralized Workflow Orchestration

Prove you are compliant, protect who you are.

BLI Legal Tech Hackathon 2 · LegalTech & RegTech · Chainlink CRE bounty · Live on Sepolia

Demo https://web-3-0-decentralized.vercel.app/zk-cid

Code https://github.com/juangh123/WEB-3.0-Decentralized

Web3 is forced to choose: compliance or privacy

Both sides of today's KYC model fail someone.

- Traditional KYC hands passports, faces and home addresses to every service. One breach leaks everything.
- Fully anonymous DeFi carries AML and sanctions risk that institutions cannot take on.
- Screening usually happens once, at onboarding. Designations made later slip through, and revocation is manual and slow.
- Age checks today mean collecting ID documents from children: the opposite of data minimisation.

> "Trust is currently misplaced: either on a data honeypot, or on no one."
>
> GDPR and AML duties have to coexist. ZK-CID makes them complementary.

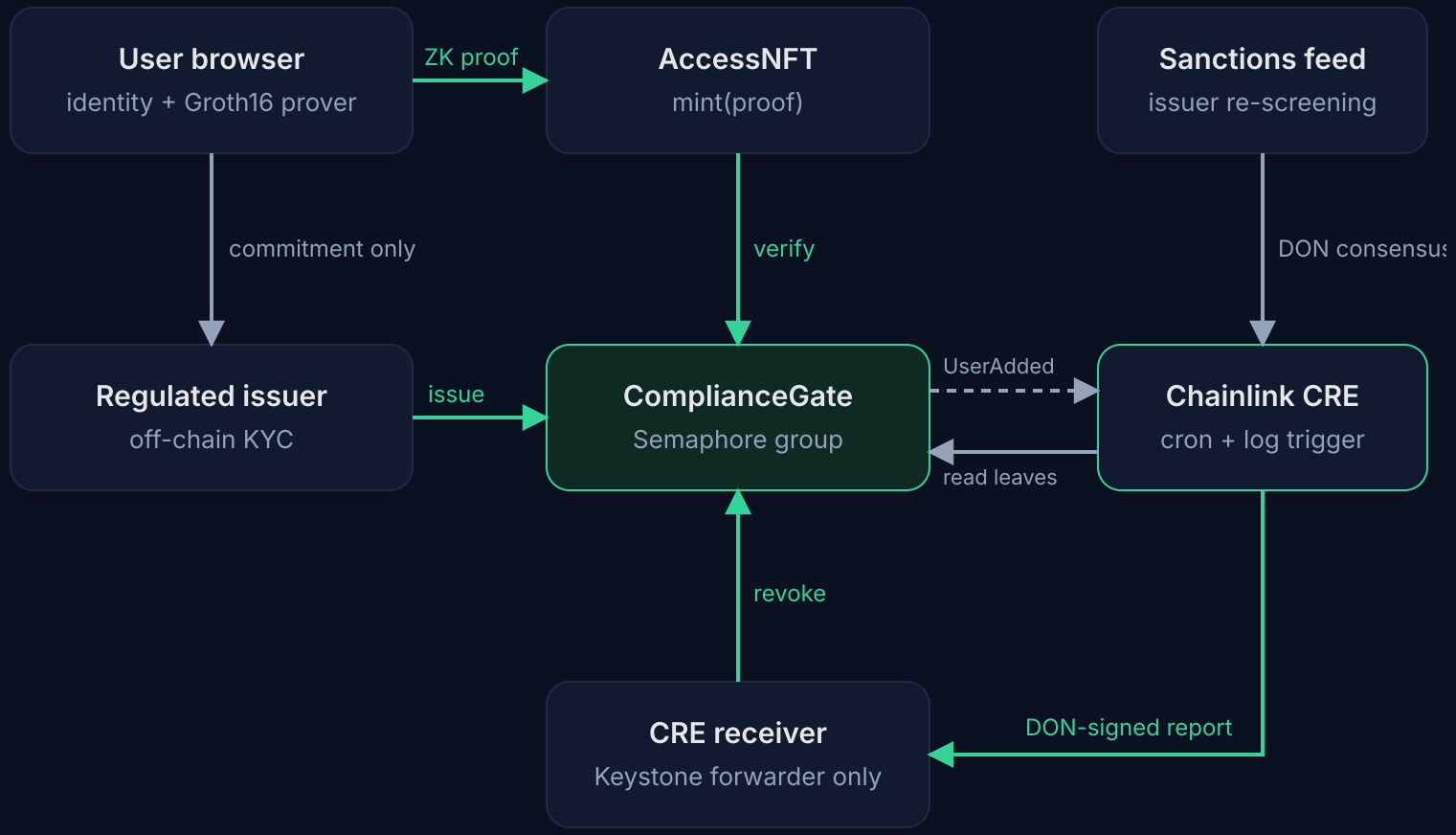
Prove compliance without revealing identity

And keep that status current automatically.

1. A regulated issuer verifies the user off-chain (documents, sanctions screening).
2. Only an anonymous Semaphore commitment is added to the on-chain compliance group.
3. The user proves membership with a zero-knowledge proof made in the browser and bound to their wallet.
4. ComplianceGate checks it with the real Semaphore v4 verifier, then AccessNFT mints the pass. Each proof works once.
5. A Chainlink CRE workflow screens at issuance and every 5 minutes, and revokes listed members on-chain.

Architecture

Privacy on the verifier side, decentralized trust on the issuer side.



ZK	Semaphore v4 (Groth16, LeanIMT)
Contracts	Solidity 0.8.28, Hardhat 3, OpenZeppelin
Frontend	Next.js, Scaffold-ETH 2, wagmi, viem
Workflow	Chainlink CRE TypeScript SDK 1.16, CLI 1.36
Network	Ethereum Sepolia
Data	Mock sanctions API (Vercel)

Chainlink CRE: the compliance lifecycle

One workflow, two triggers, one revocation path.

Handlers

`0 · cron` every 5 min: re-screen every member

`1 · EVM log` `UserAdded`, finalized: screen each new credential at issuance

Pipeline

- HTTP fetch of the sanctions feed, identical-result DON consensus
- `getMembers()` / `getLeaves()` at the finalized block
- Rebuild the Semaphore tree (LeanIMT + Poseidon in WASM), real Merkle siblings
- DON-signed report → `writeReport` → receiver → on-tree revocation

Evidence

- ✓ Official CRE CLI 1.36 build + `simulate` against live Sepolia: `{"status":"revoked"}`
- ✓ A CRE report produced a real on-chain revocation (tx 0xb64c050e…)
- ✓ Receiver follows the official ReceiverTemplate pattern and is source-verified
- ✓ 11 TestRuntime workflow tests cover both handlers; 34 contract tests
- ✓ Running simulate exposed 3 runtime defects, all fixed and documented
- ⏳ Scheduled DON execution follows Chainlink's commercial onboarding (requested 3 Oct)

Try it in 3 minutes, no wallet needed

web-3-0-decentralized.vercel.app/zk-cid

1. Generate an anonymous identity in the browser.
2. Demo issuer adds the commitment to the group on Sepolia.
3. Generate the Groth16 proof locally.
4. Verify it without gas: an eth_call runs the real strict-mode verifier on the live contracts.

Live on Sepolia

Verification	Strict mode since 10 Oct
First mint	17 Oct, real proof (tx 0x03b17a4d…)
Revocations	Real Merkle-proof removals on-chain
Source	Verified on Blockscout + Sourcify
Tests	CI: contracts, unit, workflow, API, E2E
Video	2:48 pitch + 34 s acceptance clip

How ZK-CID compares

Same compliance guarantee, a fraction of the data exposure.

	Classic KYC gate	KYC token / soulbound badge	ZK-CID
What the dApp learns	Full identity	That this wallet passed KYC	**Only that a valid proof was given**
Wallet ↔ person link	Stored by every service	Public and permanent	**None on-chain; unlinkable within the group**
New sanctions	Manual review	Manual burn or revoke	**Automated: CRE at issuance + every 5 min**
Breach impact	Full PII	Identity graph of wallets	**No PII at the dApp or on-chain**
Replay / theft	Session-based	Transferable unless soulbound	**Proof bound to wallet, single-use nullifier**

Privacy grows with group size: a production group holds an issuer's whole customer base, the demo group only a handful. CRE automation is CLI-simulated today; scheduled DON execution follows Chainlink onboarding.

Regulatory fit

A technical control that maps onto existing duties. Not legal advice.

GDPR

Data minimisation (Art. 5) and privacy by design (Art. 25): only a pseudonymous commitment and a nullifier go on-chain; PII stays with the issuer.

Sanctions (OFAC, EU)

Screening at onboarding and continuously, automated revocation, and a restoration path for false positives.

Minors and age assurance

GDPR Art. 8, COPPA, UK Online Safety Act: an "over 18" group lets a service gate by age without ever storing a birth date or ID.

FATF Travel Rule, MiCA

Complementary to a VASP/CASP's own AML programme; the issuer stays accountable for KYC.

Requirement-by-requirement mapping with open gaps: zk-cid/deliverables/LEGAL_MAPPING.md

Who pays, and why

Proposed model: compliance that removes data liability instead of adding it.

Verifiers

DeFi pools and RWA platforms that must restrict access. Pay per verification or a subscription to gate pools without ever holding PII.

Issuers

KYC providers issue reusable ZK credentials. One check, many venues; revenue per credential without sharing customer data.

Compliance teams

Continuous screening and revocation as a managed CRE workflow, with on-chain evidence auditors can replay.

Go-to-market: start with permissioned DeFi and RWA venues that already have to KYC every investor, then add attribute groups (age, accredited investor, jurisdiction).

Why now

- MiCA has applied in full across the EU since 30 December 2024, so crypto-asset service providers need AML controls that work on-chain.
- UK age checks under the Online Safety Act have been enforced since 25 July 2025, which pushes services towards checking age without hoarding ID documents.
- Sanctions designations keep changing after onboarding, and one-time screening cannot keep up.

Status and roadmap

Built, deployed and evidenced, with the gaps stated openly.

Done

- ✓ Strict-mode ZK verification live on Sepolia
- ✓ CRE workflow: CLI-simulated cron handler, a real revocation tx, and a new issuance trigger
- ✓ Gas-free on-chain verification for anyone
- ✓ Verified contracts; CI with contract, unit, workflow, API and E2E tests
- ✓ Regulatory mapping with open gaps

Next

- → DON deployment after Chainlink onboarding
- → Pass expiry so revocation reaches minted passes
- → Licensed sanctions feed and human review queue
- → Attribute groups (18+, accredited) with per-app scopes
- → A KYC provider as the first production issuer



Thank you.

Private by design, compliant by proof.